

Governing AI Under the EU AI Act

with Prof. Helmut Krcmar, TUM & Uli Homann, Microsoft
Board Agora Discussion Session / 5th May 2026 / Munich

EXECUTIVE SUMMARY

AI governance has entered a third and more demanding phase. Boards that have approved an AI strategy anchored in generative chat applications are now governing something categorically different: agentic systems that do not answer questions but pursue goals, invoking enterprise tools, triggering workflows, and executing decisions at machine speed with limited human intervention.

The EU AI Act's full enforcement regime for high-risk systems takes effect on 2 August 2026. Most boards are already deployers of high-risk AI – embedded in HR, credit, and procurement platforms – without having made that determination deliberately. The compliance window is not approaching; it is here.

What an agent can do is determined by three elements: the model that reasons on its behalf, the knowledge it has access to, and the enterprise tools it can invoke. Each of these is a governance decision, not a technology default. The board's practical levers – scoping what agents know, limiting what they can do, and requiring verifiable agent identities – map directly onto the delegation and authority frameworks boards already operate.

Because frontier AI models are black boxes – their training data proprietary, their reasoning opaque – the traditional governance model of explainability has given way to observability: logging what agents receive, plan, and produce, and evaluating that data continuously against policy and regulatory requirements. An agent estate without identity, observability, and evaluation in place is, in practice, ungovernable. Human oversight, as required by Article 14 of the Act, cannot be satisfied by instructing an AI system to ask before acting. It must be implemented as an external policy boundary in the orchestration layer – a deterministic control that intercepts an agent's proposed action and either approves, holds, or refuses it, independently of the agent's own behaviour.

When AI makes or influences decisions about people – in hiring, performance management, credit, or access to services – the regulatory and reputational stakes are highest. This is where the Act's most demanding provisions cluster, and where boards should apply the most rigorous scrutiny, regardless of their overall posture toward AI adoption.

The board's role in AI governance is not solely oversight. Agentic AI is a transformation of how the organisation operates and competes. Boards that treat it as a technology programme to monitor will find that the consequential decisions – what AI may decide, what it may access, and where human judgment remains non-negotiable – have already been made by the time a governance report arrives.

Partner governance has become a board-level responsibility. Organisations cannot transfer their deployer obligations under the Act to a vendor. Understanding which model a supplier is using, whether enterprise data is being used to train that model, and how decisions are logged and auditable is no longer a procurement footnote – it is a compliance requirement with GDPR-scale penalties attached.

The geopolitical context is not separable from the governance question. With the United States treating AI as a strategic race rather than a shared governance challenge, European organisations operating internationally cannot assume that regulatory compliance in one jurisdiction resolves exposure in others. Boards of internationally active companies should expect to navigate multiple, partially inconsistent frameworks for the foreseeable future.

The practical response is not to slow adoption, but to match it with commensurate investment in assurance: governing what agents know, what they can do, and what they actually do – under a clear accountability model, with the board’s questions asked before the incident, not after it.

1. THE LANDSCAPE: THREE WAVES, NOT ONE

The session opened with a deceptively simple observation: most boards are governing the wrong version of AI. The EU AI Act was drafted when machine learning – deterministic, white-box, explainable – was the dominant paradigm. By the time it entered force, generative AI had already become the enterprise baseline. And by the time its high-risk provisions become fully enforceable on 2 August 2026, the technology has moved again, into a third wave: agentic AI. Understanding this sequence matters, because each wave changes what governance means.

Wave 1 – Models

Large language models – GPT-4 and its successors – marked the arrival of probabilistic, black-box reasoning at enterprise scale. Three frontier providers now define this space: OpenAI, Anthropic, and Google Gemini. European models, including Mistral, have retreated to specialised niches. The implication for boards is already structural: if an organisation’s core reasoning capability depends on a small number of US-headquartered providers operating closed-source models, procurement diligence and contractual protections are not optional.

Wave 2 – Applications

The second wave brought generative capability into familiar interfaces – chat assistants, productivity co-pilots, document drafting tools. Most organisations are here today. The governance challenge in this wave is primarily one of access controls and data hygiene: who can feed what into a consumer-grade tool, whether enterprise data is being used to train underlying models, and whether employees understand the difference. The risks are real but manageable. The governance primitives are recognisable.

Wave 3 – Agents

The third wave is where governance assumptions begin to break. Agentic AI systems do not respond to prompts – they pursue goals. They perceive a context, reason over it, generate a plan, invoke enterprise tools, and act. They can trigger workflows, write to systems of record, execute transactions, and engage other agents – all at machine speed, often with no human in the loop. Two categories are emerging in practice: digital workers that collaborate with human teams in real time, and autonomous process agents that operate largely without human contact, driving back-office or manufacturing workflows end to end.

"Agents are brains on sticks. They have no inherent capability – only what you give them access to. Which is precisely why what you give them access to is the governance question."

This distinction – between AI that informs and AI that acts – is the hinge on which the session turned. The EU AI Act was not written for agents. It does not use the word. But the board-level obligations it creates – risk management, record-keeping, human oversight, transparency – become both more urgent and harder to discharge when the subject is a system that acts rather than one that answers.

2. THE ARCHITECTURE OF AN AGENT: WHAT BOARDS NEED TO UNDERSTAND

A recurring theme in the session was the gap between the language boards use to govern and the language needed to understand agentic systems. One participant observed that boards have long governed under uncertainty – delegating authority, setting limits, managing by exception – and that the architecture of AI agents is, at a structural level, not so different from the governance of a complex organisation. The terminology is new. The underlying logic is not.

Three elements together define what an agent can do.

Model – the reasoning engine

The model is the probabilistic reasoning capability at the core of any AI agent. It is trained on vast corpora of data, operates as a black box (the algorithms are not transparent, the training data is largely proprietary), and produces outputs that shift subtly over time as providers update and iterate. This is why the EU AI Act's original provisions – designed for deterministic, white-box machine learning – sit awkwardly around generative and agentic systems. The industry response has been a shift from trying to explain the model to observing its behaviour: controlling and logging what goes in, and evaluating what comes out.

For boards, the model question is a procurement question: which providers are in use, under what terms, in which jurisdictions, and with what governance posture? Organisations that have not asked which frontier model underpins an embedded HR, credit, or recruitment tool – and whether its provider has made credible commitments under applicable regulation – may already be deployers of high-risk AI without having made that determination deliberately.

Knowledge and Memory – what the agent reads and recalls

The distinction between knowledge and memory attracted significant discussion. Knowledge is the curated, authoritative information the enterprise makes available to an agent: policies, procedures, product documentation, regulatory texts, structured data. It is read-mostly, managed, and should be governed for provenance, freshness, sensitivity classification, and access entitlement. Memory is the contextual state an agent accumulates during operation – recent conversation, intermediate reasoning, user preferences. It is read-write, can be highly personal, and must be governed for retention, consent, and isolation between users and sessions.

In practice, most organisations are not yet distinguishing between the two. Every agent currently brings its own memory service, with no established interoperability standard. For a board member governing a company deploying multiple agents, this creates immediate GDPR exposure: where is personal data being stored, under what retention policy, in which jurisdiction, and who has access? These are not IT questions. They are governance questions surfaced by technical architecture.

The session's practical observation: an agent that is reliably correct depends on well-governed knowledge. An agent that merely remembers confidently – without sound institutional knowledge beneath it – will produce plausible-sounding errors at scale.

Tools – the enterprise resources an agent can act upon

An agent without tools can only advise. An agent with tools can act read from and write to the SAP system, trigger a procurement workflow, adjust a production line parameter, execute a payment. Tools are exposed to agents via Model Context Protocol (MCP), an open standard that translates enterprise APIs into a form language models can reason over. The governance implication is direct: every tool granted to an agent is a decision about authority.

Under what identity does the agent call that tool? With whose permissions? What actions are read-only versus write-enabled? Are high-impact actions subject to a propose-and-confirm pattern, where a human – or a second policy engine – approves before execution? These are the questions enterprise architecture must now answer, and they are, in substance, the same questions boards ask when setting financial authorities, approval thresholds, and delegation limits for human managers. The language is different; the governance logic is familiar.

3. THE EU AI ACT: WHAT BOARDS ARE ACTUALLY ACCOUNTABLE FOR

The EU AI Act was not written for agents. It was written, in the main, for machine learning systems that make or influence decisions affecting people: HR selection, credit scoring, critical infrastructure, clinical triage. Those use cases remain directly in scope. The compliance clock running toward 2 August 2026 is real, and the penalty regime – up to €35 million or 7% of global annual turnover at the highest tier – is comparable to GDPR in scale.

Several observations from the session warrant board attention.

Most boards are already deployers of high-risk AI

High-risk systems under the Act include AI used in recruitment and workforce management, credit and insurance decisions, critical infrastructure management, and access to essential services. Many organisations run these functions on enterprise software platforms that embed AI – often without the board having explicitly reviewed the AI governance posture of the embedded system. The deployer, under the Act, cannot transfer its compliance obligations to the vendor. Reviewing third-party AI at the point of procurement, and at regular intervals thereafter, is not an exercise the compliance function alone can discharge.

The Act's transparency assumptions do not map cleanly onto generative models

The Act assumes a level of algorithmic transparency – explainable outputs, accessible training data, auditable decision trails – that frontier generative models do not provide. Providers of large-scale closed models will not publish their training data; it is their core intellectual property. This creates a genuine legal uncertainty that is not yet resolved, and which boards operating across jurisdictions should monitor actively. The industry is converging on observability – logging inputs, outputs, and agent plans – as the practical substitute for explainability. Whether that substitution will satisfy regulators and courts is an open question.

Human oversight must be an external constraint, not a prompt instruction

Article 14 of the Act requires effective human oversight to be built into high-risk systems as a design feature, not expressed as a request to the system itself. A system prompt telling an agent to 'ask before approving payments above a threshold' is part of the agent's behaviour – and can be circumvented by the same model following the instruction. Effective oversight is implemented in the orchestration layer: a deterministic policy engine that intercepts a proposed action and either executes, holds for human approval, or refuses, independently of what the agent itself believes it should do.

Several participants noted that this framing maps well onto existing board governance logic: the agent is the manager, and the policy engine is the delegated authority framework. Boards set the parameters; architecture enforces them.

The geopolitical dimension

The session did not avoid the wider context. With the current US administration having declared AI a strategic race against China, the norms that European regulation is attempting to embed – human oversight, transparency, proportionality – are not being replicated at the frontier of AI development. One participant drew the analogy to the Cold War arms race; another noted that European companies operating internationally cannot simply comply with the AI Act and assume the matter closed. Digital sovereignty provisions, shifting US regulatory stances, and the emergence of physical AI in manufacturing all add complexity that the Act, as drafted, does not address. Boards of internationally active organisations should expect to navigate multiple, partially inconsistent frameworks simultaneously.

4. THE GOVERNANCE FRAMEWORK: OBSERVE, EVALUATE, CONTROL

Machine learning governance was built on explainability: if you understand the algorithm and the training data, you can predict and validate the outcome. Agentic AI governance cannot work this way. The reasoning is probabilistic, the model is a black box, and the outputs shift over time. The industry has converged on a different model: observability and continuous evaluation.

Observability: logging what the agent sees, plans and does

The open standard for AI agent observability, built on OpenTelemetry (an existing industry standard for IT monitoring, now being extended to cover agent-specific concepts such as plans, tool calls, and intermediate reasoning steps), allows organisations to log everything the agent receives as input, every action it proposes, and every output it produces. This logging is the substrate of Article 12 compliance under the Act, and the foundation of any meaningful post-incident forensic capability. An agent estate without observability is, in practice, ungovernable.

One practical problem highlighted in the session: if multiple agents from different vendors are deployed without a common observability schema, the board is left stitching together four incompatible management models. The push toward open standards – and the requirement that vendors conform to a shared semantic understanding of agent telemetry, not merely sign up to the standard in principle – is a procurement and contractual ask that boards can and should make.

Evaluation: AI agents watching AI agents

Observability produces data. Evaluation converts that data into a governance signal. Given the volume of agent actions – thousands per day, in mature deployments – human review of individual actions does not scale. The emerging model is continuous automated evaluation: code-based checks for policy violations, AI models that review agent outputs and flag anomalies, and periodic human review of sampled interactions. The observation that this will involve AI agents watching AI agents was not lost on participants. It introduces its own governance questions – but it is the only approach that scales.

Evaluation services will evolve, the session suggested, from technical assurance into something closer to business assurance: evaluating not just whether the agent behaved within technical guardrails, but whether the business outcomes it produced were appropriate. Red-teaming, adversarial testing, and scenario-based evaluation are becoming standard elements of AI assurance – and the board should expect to see these addressed in AI governance reports, not left implicit.

Control: the choke points boards can use

The practical message for governance: boards do not need to understand the model to govern the agent. The two levers that constrain what any agent can do are knowledge (what institutional context it has access to) and tools (what enterprise resources it can invoke). Narrow knowledge bases increase reliability and reduce the risk of hallucination in regulated domains. Scoped, read-first tools with propose-and-confirm patterns on write operations create the human-in-the-loop without requiring

real-time oversight of every action. Identity – the requirement that every agent carries a verifiable, distinct identity, not borrowed from the human user – makes audit trails defensible and access controls enforceable.

The framework the session returned to repeatedly: identity, observability, evaluation. No agent should enter production without all three. And the board's standing question to management should be: what is our coverage rate across the agent estate, and how is it trending?

5. THE BOARD'S ROLE: FROM OVERSIGHT TO DRIVING SEAT

One of the session's sharpest exchanges centred on a question from the floor: is the board's role in AI governance oversight, or something more? The answer that emerged was neither comfortable nor simple.

Oversight – the traditional supervisory role – is necessary but insufficient. Agentic AI is not a technology project that management runs and the board monitors. It is a transformation of how the organisation operates, competes, and makes decisions. Boards that treat it as the former will find that by the time they receive a governance report, the significant decisions have already been made.

The efficiency-judgment distinction

A participant drew a distinction that resonated across the room: training for AI should be training for judgment, not training for tool proficiency. Boards and senior executives who become expert users of AI tools have acquired a useful skill. Boards and executives who develop the judgment to ask what decisions the organisation is delegating to AI, under what conditions, with what oversight, and to what ends, have acquired something more valuable.

The risk identified was the efficiency trap: deploying AI to optimise processes without asking whether those processes, optimised, still serve the organisation's purpose. AI in HR that accelerates screening decisions may simultaneously entrench the biases the organisation has spent a decade trying to remove. Efficiency is not a substitute for judgment about outcomes.

Purpose before architecture

Several participants pushed back, gently, on the tendency – noted in technical presentations – to begin the AI governance conversation with architecture. The prior question, they argued, is purpose: what are we adopting AI to achieve? What outcomes do we expect? Where do we want human judgment to remain irreplaceable, and where are we willing to accept machine judgment under human supervision? These are questions the board can and should answer – and the answers should precede, not follow, the technology investment.

The 'Frontier Firm' model – a maturity assessment framework that maps an organisation's current state of human-led versus AI-assisted versus automated activity across its key functions – was offered as one tool for making this conversation concrete. The point was not to advocate a particular framework, but to insist that the conversation happen at all, and that it happens at board level.

People decisions: the highest-risk category

One observation from the session carries particular weight for boards: when AI makes or influences decisions about people – employees, customers, citizens – the risk profile changes entirely. The EU AI Act's most demanding provisions cluster here. The Air Canada chatbot case, in which a hallucinated refund policy created reputational and financial liability for the airline, is the canonical illustration at the customer end. At the employee end, the obligations under Articles 9 (risk management), 14 (human oversight), and 50 (transparency to affected individuals) are not checkbox compliance – they require genuine architectural investment.

The session's recommendation: even boards that accept a permissive posture toward AI in finance, procurement, or manufacturing should apply elevated scrutiny to any system that affects hiring, performance assessment, credit, access to services, or clinical decision-making. That is where the Act's teeth are sharpest, and where an incident is most likely to produce lasting reputational damage.

De-risking in an uncertain environment

The session closed with a practical question: what should boards be doing now, given regulatory uncertainty, geopolitical flux, and the pace of technical change? Three propositions attracted broad agreement.

- Invest in knowledge before pilots. The foundation of any trustworthy agent is sound institutional knowledge, properly governed. Organisations that invest in a managed knowledge layer first will find their subsequent AI deployments more reliable, more compliant, and easier to govern.
- Take small, accountable steps. The temptation, particularly in German-speaking corporate culture, is to wait until the full scope is understood before beginning. The better approach is to move in bounded, observable steps – with clear accountability for each – and to learn from each before scaling.
- Make the right partnerships. Building AI capability independently is a fool's errand for most organisations. The question is not whether to partner, but with whom, and on what terms. Partner governance – understanding what model a vendor is using, how it stores data, how it produces and logs decisions, and whether it complies with applicable regulation – is now a board-level responsibility.

Acknowledgements

This knowledge paper synthesises insights from the Board Agora discussion session held on 5 May 2026. We extend our gratitude to Prof. Helmut Krcmar and Ulrich Homann for their expert contributions, and to all participating board members whose candid reflections and challenges enriched this dialogue. The quality of a Chatham House conversation depends entirely on the willingness of participants to speak with genuine honesty.



Board Agora Knowledge Paper

*Governing AI Under the EU AI Act/ May 2026 / Operating under Chatham House
Rules*